EXPERIMENT – 6

Password Policy and Authentication Hardening on Kali Linux

Aim

To configure and test password complexity, password aging, and account lockout policies in Kali Linux.

Requirements

- Kali Linux Virtual Machine
- Terminal
- sudo access

Safety: Perform this experiment only on a disposable Kali Linux VM. Use the test account `labuser`. Do not test account lockout on your main account.

---

1. Install Required Package

Open the Terminal and execute:

```
sudo apt update
sudo apt install -y libpam-pwquality
```

---

2. Create Test User

```
sudo adduser labuser
```

Enter the required details and set a temporary password.

---

3. Configure Password Policy

Open the password-quality configuration file:

```
sudo nano /etc/security/pwquality.conf
```

Add or update the following:

```
minlen = 12
dcredit = -1
```

```
ucredit = -1
lcredit = -1
ocredit = -1
```

Policy

- Minimum password length = **12 characters**
- At least one uppercase letter
- At least one lowercase letter
- At least one digit
- At least one special character

Save the file:

Ctrl + O → Enter → Ctrl + X

Check that `pam_pwquality` is enabled:

```
grep pam_pwquality /etc/pam.d/common-password
```

---

4. Configure Password Aging

Open:

```
sudo nano /etc/login.defs
```

Set:

```
PASS_MAX_DAYS   90
PASS_MIN_DAYS   1
PASS_WARN_AGE   7
```

Save the file.

Apply the settings to `labuser`:

```
sudo chage -M 90 -m 1 -W 7 labuser
```

Check the settings:

```
sudo chage -l labuser
```

Expected

- Maximum password age = **90 days**
- Minimum password age = **1 day**
- Warning period = **7 days**

---

5. Configure Account Lockout

Open:

```
sudo nano /etc/security/faillock.conf
```

Add:

```
deny = 3
fail_interval = 900
unlock_time = 600
```

Meaning

Setting	Value	Meaning
`deny`	3	Lock after 3 failed attempts
`fail_interval`	900	Count failures within 15 minutes
`unlock_time`	600	Unlock after 10 minutes

Save the file.

---

6. Enable `pam_faillock`

Open:

```
sudo nano /etc/pam.d/common-auth
```

Ensure the authentication section contains:

```
auth required pam_faillock.so preauth
auth [success=1 default=bad] pam_unix.so nullok
auth [default=die] pam_faillock.so authfail
auth sufficient pam_faillock.so authsucc
```

grep -n "pam_faillock" /etc/pam.d/common-auth

---

7. Test Password Complexity

Set a new password:

```
sudo passwd labuser
```

Test 1 – Weak Password

Try a weak password.

Expected: Password should be rejected.

Test 2 – Strong Password

Use a password containing:

- Uppercase letter
- Lowercase letter
- Number
- Special character
- At least 12 characters

Expected: Password should be accepted.

---

8. Test Account Lockout

Open another terminal.

Run:

```
su – labuser
su – labuser
su - labuser
```

Enter the **wrong password three times**.

From the sudo terminal, check the failed attempts:

```
sudo faillock --user labuser
```

Expected Result:
The failed login attempts should be displayed.

Now try to log in again using:

```
su - labuser
```

---

9. Remove the Account

Sudo userdel -r labuser

Verification

Test	Expected Result	Status
Weak password	Rejected	Pass / Fail
Strong password	Accepted	Pass / Fail
`chage -l labuser`	Shows 90 / 1 / 7 days	Pass / Fail
Three wrong passwords	Account locked	Pass / Fail
Fourth attempt	Login denied	Pass / Fail
`faillock --reset`	Login works again	Pass / Fail

Precautions

1. Perform the experiment only in a **Kali Linux VM**.
2. Use **`labuser`** for testing.
3. Do not test lockout on the main/root account.
4. Keep one authenticated `sudo` terminal open while modifying PAM files.
5. Use a temporary password that is not used elsewhere.

Result

The password and authentication security policies were successfully configured and tested.

The experiment is successful if:

- Weak passwords are rejected.
- Strong passwords are accepted.
- Password aging is correctly configured.
- `labuser` is locked after three failed attempts.
- Resetting `faillock` allows the user to log in again.